POOJA KIRAN | SECURITY ENGINEERING

Runtime Policy Enforcement at the AI Agent-to-Tool Boundary

Design and Validation of an Inline MCP/JSON-RPC Security Gateway

Source inventory: a00d23c69e5e56aac12d09e57b790cfb92b47062

Test snapshot: 008775c8878cc70c50247baa223da3256e093316

CI run 37184196303 | initiated 2026-10-04 UTC | MIT

https://github.com/poojakira/mcp-agent-security-gateway

723
tests passed in cited CI

81.91%
statement coverage, same CI job

55
pattern entries at historical test snapshot

9
Elastic rule records, source inventory

CONTRIBUTION

- MCP policy and inspection components return decisions and hash-chained audit evidence across supported integration paths; callers and transports have distinct enforcement responsibilities.

IMPLEMENTED METHOD

- 1. Parse and validate JSON-RPC, including duplicate-key and malformed-input rejection.
- 2. Normalize potentially obfuscated content before inspection.
- 3. Evaluate server trust, capabilities, and content/policy signals.
- 4. Return allow/block decisions using path-specific enforcement semantics.
- 5. Record hash-chained audit evidence and SIEM-oriented telemetry.

LIMITATIONS AND EVIDENCE BOUNDARY

- PolicyEngine provides tool/server and egress policies; stdio inspection applies detector/rate checks, not one universal five-stage gate.
- HTTP inspection callers must honor returned decisions. Controls apply only to traffic through the implemented integration paths.
- No production deployment, universal prevention, detector effectiveness or external pilot result is established.

SCOPED EVIDENCE

- Cited Python 3.12 CI: 723 passed, 81.91% statement coverage (5,644 statements, 1,021 missed); Python 3.10/3.11 jobs also succeeded.
- The historical detector collection has 55 entries. A later dated inventory at c30075da1dc1d3fa7b843bb76be8e842fbfa6ae3 has 69 entries; these are inventory counts, not accuracy rates.
- Cited job and source inventory: 21 core SIEM test functions and 7 scenario test functions, plus 9 Elastic rule records.
- Reported development-set result for the later detector: 15/15 attack samples flagged and 3/15 benign flags. Not independently rerun here; not population precision/recall.

REPRODUCTION

- git checkout 008775c8878cc70c50247baa223da3256e093316
- Install the documented development extras and run python -m pytest tests/ -q using the cited Linux CI configuration.
- A different platform or dependency set may produce different counts/coverage. This poster is not a promise about the latest main.

Dated tests and committed fixtures do not establish universal detection, production deployment or an SLO.